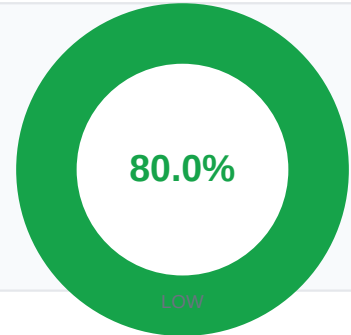


Document: auditq_upload.pdf
Generated: 12 June 2026 15:24
Model: Qwen/Qwen2.5-7B-Instruct
Embeddings: BAAI/bge-small-en-v1.5 | FAISS IndexFlatIP



OVERALL COMPLIANCE SCORE

80.0%

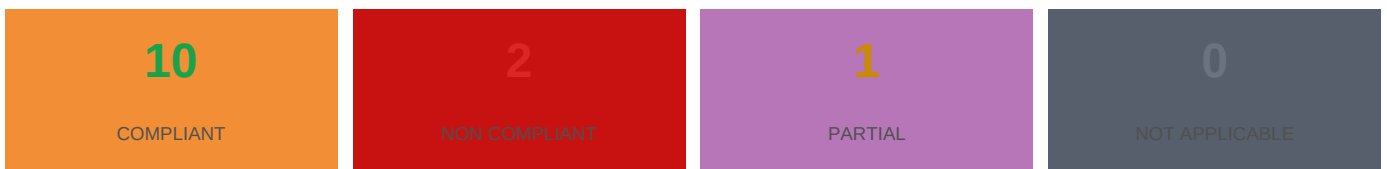
Risk Level: LOW | Rules Checked: 13 | Tokens: 7355 | Avg Latency: 9.4s/chunk



COMPLIANCE SCORE BY FRAMEWORK



VALIDATION STATUS SUMMARY



DETAILED COMPLIANCE FINDINGS

GDPR

GDPR-002 **PART** **HIG**  70%

While interim retention periods are mentioned, a formal, documented data retention schedule has not been approved.

Evidence: The Company acknowledges that a comprehensive, documented data retention schedule covering all data categories has not yet been formally approved by the Data Protection Officer.

Gap: A formal, documented data retention schedule has not been approved.

Action: Formalize and document the data retention schedule for all data categories.

GDPR-005 **PASS** **MED**  88%

The document references the existence of a data processing agreement with a third party.

Evidence: This agreement covers compliance obligations under GDPR, SOX, HIPAA, PCI-DSS, and Insurance/Financial Services regulations applicable to GlobalFinTech Corp.

GDPR-004 **PASS** **CRI**  91%

The document explicitly states the 72-hour reporting timeline.

Evidence: "the Company will assess the risk to data subjects and notify the relevant supervisory authority (ICO in the UK) within 72 hours"

GDPR-005 **PART** **MED**  79%

While most third-party agreements are compliant, some are not yet in place.

Evidence: "Data Processing Agreements (DPAs) compliant with Article 28 of GDPR have been executed with 39 of these processors. Eight processors, primarily recent onboarding during Q4 2025, do not yet have executed DPAs in place."

Gap: Eight third-party processors do not yet have GDPR-compliant Data Processing Agreements in place.

Action: Complete the execution of Data Processing Agreements with the remaining eight processors by Q2 2026.

GDPR-004 **N/A** **CRI**  88%

There is no mention of data breach notification procedures in the document.

Gap: A breach notification procedure with 72-hour reporting timeline is missing.

Action: Implement a breach notification procedure with a 72-hour reporting timeline.

SOX

SOX-003 **PASS** **HIG**  87%

The document specifies that customer transaction records are retained for 7 years, which aligns with the requirement.

Evidence: Customer transaction records are retained for 7 years to satisfy financial regulatory requirements.

SOX-001 **FAIL** **CRI**  70%

The ICFR framework has not been comprehensively documented for the current fiscal year.

Evidence: "Management acknowledges that formally documented Internal Controls over Financial Reporting (ICFR) as required under Section 404 of the Sarbanes-Oxley Act have not been comprehensively documented for the current fiscal ..."

Gap: The ICFR framework has not been comprehensively documented for the current fiscal year.

Action: Complete the development and documentation of the ICFR framework by Q3 2026.

SOX-003 **PASS** **HIG**  91%

The document explicitly states a 7-year retention period for financial records.

Evidence: "All financial records, general ledger entries, accounts payable and receivable records, bank reconciliations, audit

HIPAA

HIPAA-004

PASS

HIG

90%

The document mentions logging mechanisms for PHI access.

Evidence: "All PHI access is logged and monitored by the Information Security team"

HIPAA-003

PASS

CRI

88%

The document specifies a 60-day breach notification procedure.

Evidence: "In the event of a breach of unsecured PHI, the Company will notify affected individuals without unreasonable delay and within 60 days"

HIPAA-003

PASS

CRI

88%

The document explicitly states the 60-day breach notification procedure.

Evidence: Notification to the Secretary of HHS will be provided simultaneously. For breaches affecting 500 or more individuals in a state, prominent media notice will be provided.

HIPAA-004

PART

HIG

73%

Audit logging is partially implemented but not fully for all systems containing PHI.

Evidence: Audit logs are in place for the primary Workday HR system, however three legacy occupational health record systems acquired through the 2023 merger with MedCorp Solutions do not currently generate HIPAA-compliant audit l...

Gap: Audit logging is not in place for three legacy occupational health record systems.

Action: Implement HIPAA-compliant audit logging for the three legacy occupational health record systems.

HIPAA-005

FAIL

HIG

65%

Business Associate Agreements are not in place with two recently onboarded employee assistance programme providers.

Evidence: The Company maintains a register of all Business Associates updated quarterly. However, BAAs have not been executed with two recently onboarded employee assistance programme providers who may have access to PHI.

Gap: BAAs are not in place with two recently onboarded employee assistance programme providers.

Action: Execute signed BAAs with the two recently onboarded employee assistance programme providers.

PCI DSS

PCI-003

PASS

HIG

86%

The document explicitly mentions the use of a firewall and network segmentation.

Evidence: The cardholder data environment is segregated from the corporate network and public internet using a dedicated next-generation firewall (Palo Alto Networks PA-5220) with application-aware filtering. Network segmentation ...

PCI-002

PASS

HIG

86%

The document explicitly states that access is restricted based on job roles and the principle of least privilege.

Evidence: Access rights to payment processing systems have not been formally reviewed following the organisational restructuring in Q1 2026. Twelve individuals retain access rights to payment system administration consoles that ma...

PCI-004

PASS

HIG

84%

The document describes regular vulnerability scans and penetration testing procedures.

Evidence: The Company conducts quarterly internal and external vulnerability scans of all systems in scope for PCI-DSS using Qualys Enterprise. Critical and high vulnerabilities are remediated within 30 and 60 days respectively. A...

Insurance Compliance

INS-003 PASS CRI 87%

The document explicitly mentions AML and KYC procedures.

Evidence: 5.3 Anti-Money Laundering and KYC Compliance The Company operates a risk-based AML programme compliant with the Money Laundering, Terrorist Financing and Transfer of Funds Regulations 2017.

INS-004 PASS CRI 86%

The document explicitly states the capital adequacy and solvency ratios.

Evidence: The Solvency Capital Requirement (SCR) coverage ratio as at 31 December 2025 was 187%, significantly above the 100% minimum requirement. The Minimum Capital Requirement (MCR) coverage ratio was 312%.

RISK-RANKED REMEDIATION ACTION PLAN

Issues are ranked by severity. Address CRITICAL items immediately, HIGH within 30 days, MEDIUM within 90 days.

1	SOX-001	SOX	CRITICAL	NON COMPLIAN	Gap: The ICFR framework has not been comprehensively documented for the current fiscal year. Action: Complete the development and documentation of the ICFR framework by Q3 2026.
2	GDPR-002	GDPR	HIGH	PARTIAL	Gap: A formal, documented data retention schedule has not been approved. Action: Formalize and document the data retention schedule for all data categories.
3	HIPAA-005	HIPAA	HIGH	NON COMPLIAN	Gap: BAAs are not in place with two recently onboarded employee assistance programme providers. Action: Execute signed BAAs with the two recently onboarded employee assistance programme providers.

About auditq

AI-Powered Compliance Audit Validator | TCS & AMD AI Hackathon 2026 | Track 1 - Agents | Built by @hardikjp7 | github.com/hardikjp7